Monthly Intelligence Dispatch

June 2021

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- JBS Foods, a major meat producer, had to suspend the operation of several of its facilities in the United States, Australia, and Canada due to a REvil ransomware attack.
- Another, more serious incident was a REvil attack against Sol Oriens, a US nuclear weapons contractor.
- Group-IB reported that a customer database presumably belonging to DDoS-Guard, a company that offers anti-DDoS services, had been put up for sale on a popular hacker forum.
- New York Pizza (NYP), one of the largest pizza restaurant chains in the Netherlands, suffered a security breach. A hacker got their hands on the personal data of 3.9 million users, which accounts for about 22% of the population of the Netherlands.
- Threat actors breached the network of Electronic Arts (EA), a major game developer.
- A joint operation involving Interpol and Ukrainian, South Korean and US police resulted in six suspects linked to the notorious Clop ransomware being arrested.
- The US Department of Justice said that Oleg Koshkin had been convicted for his role in operating a crypting service used to conceal the Kelihos malware from antivirus software.

REvil

Recent REvil ransomware attacks have made it clear: ransomware is the number one problem, with Revil and their affiliates being one of the most active and aggressive threat actors. For instance, after a recent attack against JBS Foods, a major meat producer, the company had to suspend the operation of several of its facilities in the United States, Australia, and Canada. JBS later admitted to paying the ransomware operators a part of the ransom. By doing so the company tried to regain access to the systems affected by the attack. The threat actors received $11 million in Bitcoin (they initially demanded $22.5 million).

Sol Oriens, a US nuclear weapons contractor, has also fallen victim. The threat actors stole internal information as well as employee data including social security numbers and have already put the data up for auction. The group published screenshots of various documents as evidence. To push Sol Oriens and make the organization pay the ransom, the threat actors threatened to share the compromised data with military agencies.

Until recently, the REvil ransomware has been distributed through a public affiliate problem. This means that a fairly wide circle of cybercriminals with various levels of skill can use it. One example of cooperation is an attack on the Japanese tech giant **Fujifilm**. It was revealed that operators of the ransomware reached all internal communications systems, including email and phone systems. Security experts believe that the attack on Fujifilm involved partnership between the operators of the Qbot Trojan and Revil.

DDoS-Guard

Group-IB reported that a database presumably belonging to DDoS-Guard, a company that provides anti-DDoS, content delivery, and web hosting services, had been put up for sale on exploit[.]in, a popular hacker forum. The author of the post first auctioned the item with the starting price set at $500,000, but later lowered it to $350,000. In addition to DDoS-Guard customer data, including names, IP addresses, and payment information, the seller claims to have the source code of DDoS-Guard's infrastructure (refusing to provide database samples, however).

DDoS-Guard was recently in the center of an international scandal: in January 2021, the Russian company provided its services to Parler, a social media resource popular among supporters of the former US President Donald Trump, after the resource's hosting on the AWS platform had been stopped. In Russia, DDoS-Guard protects dozens of well-known resources, but there are also some suspicious ones.

A Group-IB report on online piracy patrons released last year mentions that DDoS-Guard's hosting and anti-DDoS services are used by online pirates, scammers, and online casinos. At the moment, Roskomnadzor (Russia's Federal Service for Supervision of Communications, Information Technology and Mass Media) restricts user access to 4,000 resources (domains and URLs) that are or have been hosted on DDoS-Guard's network addresses: in addition to pirate resources (48%), Roskomnadzor blocks many websites related to gambling (45%) and narcotics shops (4%), including Hydra mirrors and RCclub.

Scamdemic

Group-IB published an analysis of online fraud schemes. In total, fraud accounts for 73% of all online attacks: 56% are scams (deceit resulting in the victim voluntarily making a payment and revealing sensitive data) and 17% are phishing attacks (theft of bank card details). Group-IB's analysis of damage caused by fraud revealed over 70 active scam groups that used a fraudulent scheme called Classiscam; 54 of them target Russian residents.

The number of fraud cases recorded by Group-IB in Russia last year was 35% higher than the figure for 2019. In Europe, the Asia-Pacific region, and the Middle East this number grew by 39%, 88%, and 27.5% respectively.

In their attacks on banking customers, fraudsters often used fake social media accounts, with an average of over 500 fake accounts per brand. The main threat in the insurance sector was phishing: fraudsters created over a hundred phishing websites per brand.

The Classiscam scheme has been used in 44 countries. By early 2021, more than 12,500 threat actors had been using Classiscam, with 10,000 fake websites created by them. Fraudsters swindled about $9.1 million out of their victims in one year.

In another scheme, called Rabbit Hole, fraudsters lead their victims from one resource to another, stealing personal information, payment data, and money along the way. Last year, scammers used the names of famous retailers and service providers as decoys. On average, fraudulent resources had 40,000 user visits per day.

New York Pizza	New York Pizza (NYP), one of the largest pizza restaurant chains in the Netherlands, suffered a security breach. The threat actor obtained the following data about New York Pizza customers: names, delivery addresses, email addresses, phone numbers, hashed passwords for NYP accounts, and past orders. The company said the hacker got their hands on the personal data of about 3.9 million users, which accounts for 22% of the population of the Netherland. The company asked its customers to change passwords for their accounts. NYP says it expects the stolen information to be leaked online at one point in the future and that threat actors will most likely abuse the stolen information for fraud purposes (phishing, spam, and so on).
Electronic Arts	Threat actors breached the network of the gaming giant **Electronic Arts** (EA) and claim to have stolen roughly 750 GB of data, including game source code and debug tools. BleepingComputer spoke to the threat actor selling EA's data who claims to have stolen the source code of FIFA (one of the most popular EA games) and points used as in-game currency, which are likely to be used for money laundering purposes. In addition, the attackers claim that some customers are willing to pay $28 million for the stolen data.

APT28

Specialists at Cluster25 discovered new malware called SkinnyBoy, which was used by **APT28** (also known as Fancy Bear, Sednit, Sofacy, Strontium, and PwnStorm) in spear-phishing attacks against military and government entities earlier this year. According to the researchers, APT28 likely started this campaign at the beginning of March, focusing on ministries of foreign affairs, embassies, defense industry, and the military sector. Multiple victims are in the European Union but the researchers said that the activity may have impacted organizations in the United States, too. SkinnyBoy is intended for an intermediary attack stage to collect information about the victim and to retrieve the next payload from the command-and-control (C&C) server. SkinnyBoy is delivered through a Microsoft Word document laced with a macro that extracts a DLL file acting as a malware downloader. The lure is a message with a spoofed invitation to an international scientific event held in Spain at the end of July.

Arrests and sentences

Alla Witte

Alla Witte, a Latvian citizen who has been accused of helping distribute a banking Trojan and ransomware suite of malware known as **Trickbot**, was arraigned in court in Cleveland. According to the case materials, Witte, known online as Max, was part of the group behind Trickbot. When the group's botnet started operating on a commercial basis, Max became in charge of developing code for monitoring authorized use of malware, deploying ransomware, and overseeing infections and payments related to them. Trickbot was discovered by security experts in late 2015. Its authors are the creators of the Dyre banking Trojan. The successor debuted as a banking Trojan but later acquired capabilities to steal other information too as well as deliver other malware, such as Ryuk and Conti ransomware.

Clop

A joint operation involving Interpol and Ukrainian, South Korean and US police resulted in six suspects linked to the notorious Clop ransomware being arrested in Kiev and the Kiev region. Among other things, computer equipment, cars (Tesla, Mercedes, and Lexus), and five million Ukrainian hryvnias (about $185,000), which the authorities believe were obtained as ransoms, were seized. The South Korean police ramped up their investigation into the hackers last year after the group infected the network of the South Korean e-commerce giant **E-Land** in November 2020.

Oleg Koshkin

The US Department of Justice reported that Oleg Koshkin, a Russian national, had been found guilty of operating a crypting service used by the Kelihos botnet. Koshkin was arrested in California in 2019 and has been detained since his arrest. He is facing a maximum penalty of 15 years in prison. According to the prosecutors, Koshkin operated Crypt4U.com, Crypt4U.net, fud.bz, fud.re, and other websites that promised to render malware (e.g., botnets, remote-access Trojans, keyloggers, credential stealers, and cryptocurrency miners) fully undetectable by almost all major providers of antivirus solutions.

Forecasts and warnings

- REvil ransomware operators and their affiliates may attack both smaller companies (from which the threat actors are likely to demand ransoms of up to $100,000) and giants such as Acer (with ransom demands being in the tens of millions of dollars). The FBI warns companies against paying ransoms to threat actors. By agreeing to threat actors' demands, victims fund cybercrime and risk being attacked again.
- With over 10 years of experience in thoroughly analyzing online fraud, Group-IB has transitioned to using neural networks and adaptive scoring — technologies that help automate complex processes of detecting and categorizing fraud targeted at any specific company and industry in any country. Group-IB's new product, **Digital Risk Protection**, is an automated system that helps protect digital assets, brands, and personal and corporate reputation by using artificial intelligence–based technologies. In one year, the system helped companies in Russia, Europe, the Asia-Pacific region, and the Middle East prevent damages amounting to $443 million.
- The second half of 2021 may see many attacks against IT and cybersecurity companies and cloud infrastructures as well as supply-chain attacks similar to the SolarWinds hack. We recommend that all organizations thoroughly analyze their infrastructures, promptly respond to anomalies, focus on network entry points used by remote employees, and ensure the highest possible level of security by using security solutions, such as Threat Hunting Framework and Threat Intelligence & Attribution.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com